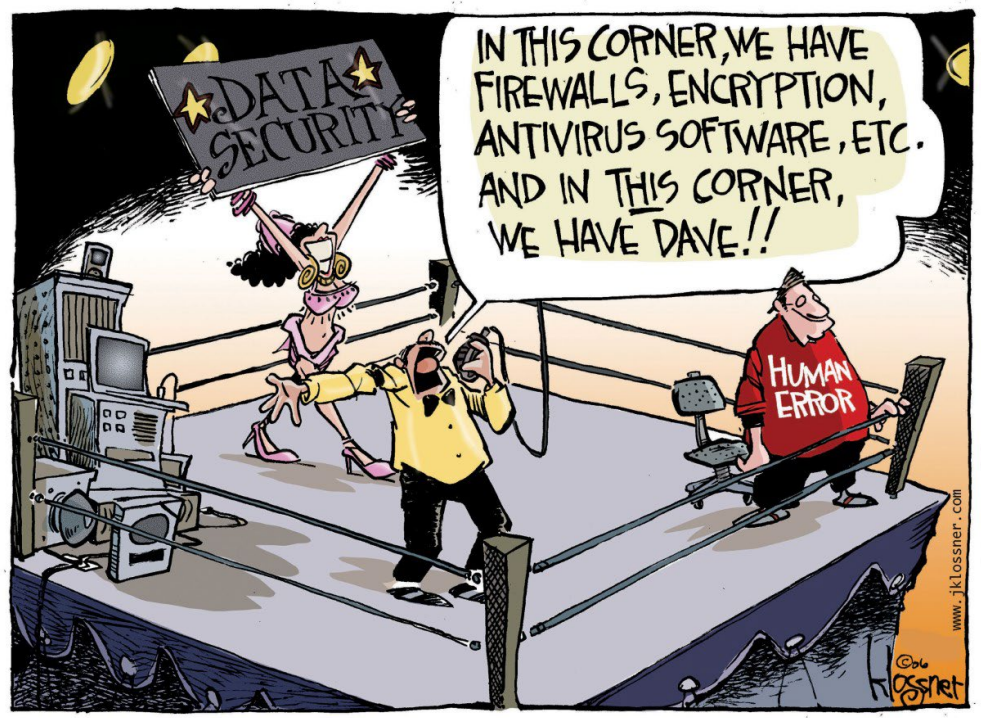
NTNU

Norwegian University of Science and Technology

TDT4237 Software Security and Data Privacy - Spring 2026



copyright 2006 john klossner www.jklossner.com
Used by permission

About Per Håkon Meland

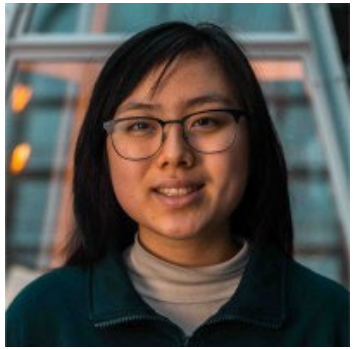
- Lecturer: Per Håkon Meland
  - MSc and PhD from IDI, NTNU
  - Visiting scholar at UC Berkeley
  - Senior Research Scientist at SINTEF (>20 years)
  - Adjunct Associate Professor at IDI, NTNU
  - per.hakon.meland@ntnu.no

About Jingyue

- Coordinator and lecturer: Jingyue Li (Bill)
  - Master (Computer science) in China
  - Architect: IBM China Ltd.
    - Bank solutions
  - PhD and Post-Doc (Software engineering) at IDI
  - Principal researcher: DNV Research & Innovation
  - Jingyue.li@ntnu.no

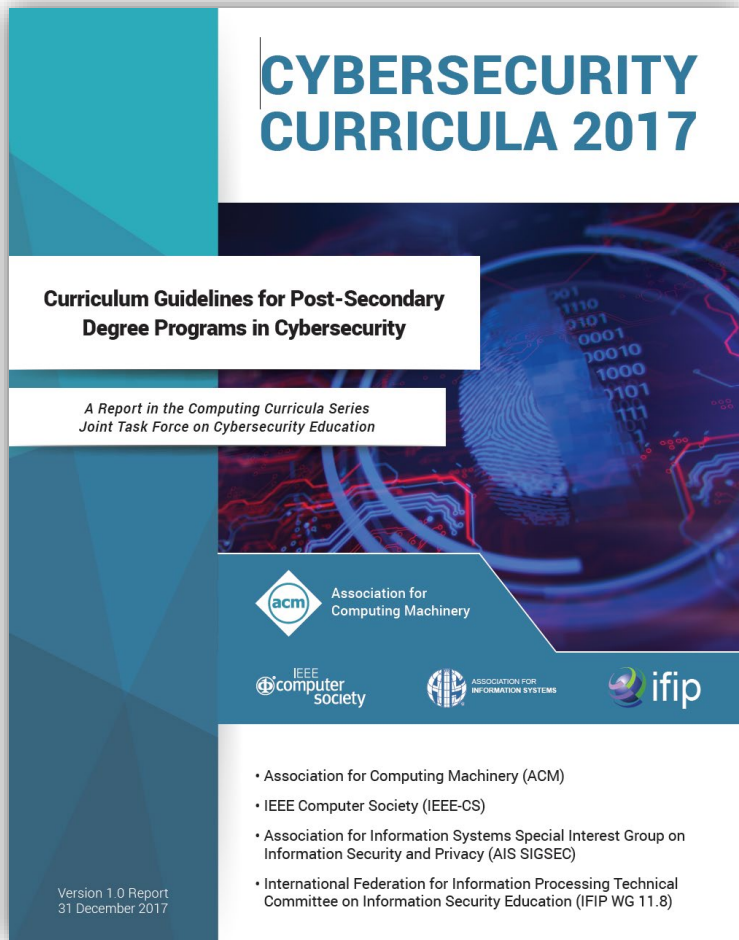
Teaching Assistants

- Torjus Østensen
- Nirushaan Selvaratnam
- Rebekka Aashaug Stangvik
- Johan Knudsen
- Alice Zheng
- Eivind Nesje
- Mohd Sameen Chishti
- …



Knowledge coverage

- Mainly according to ACM/IEEE Cybersecurity Curricula 2017
  https://www.acm.org/binaries/content/assets/education/curricula-recommendations/csec2017.pdf
- OWASP Top 10:2025
- Software security
- Data security and privacy



Software security

Software Security is the practice of building software to be secure and to continue to function properly under malicious attack.
(Gary McGraw)

Data protection

Data Privacy

Compliance with data protection laws and regulations. Focus on how to collect, process, share, archive and delete the data

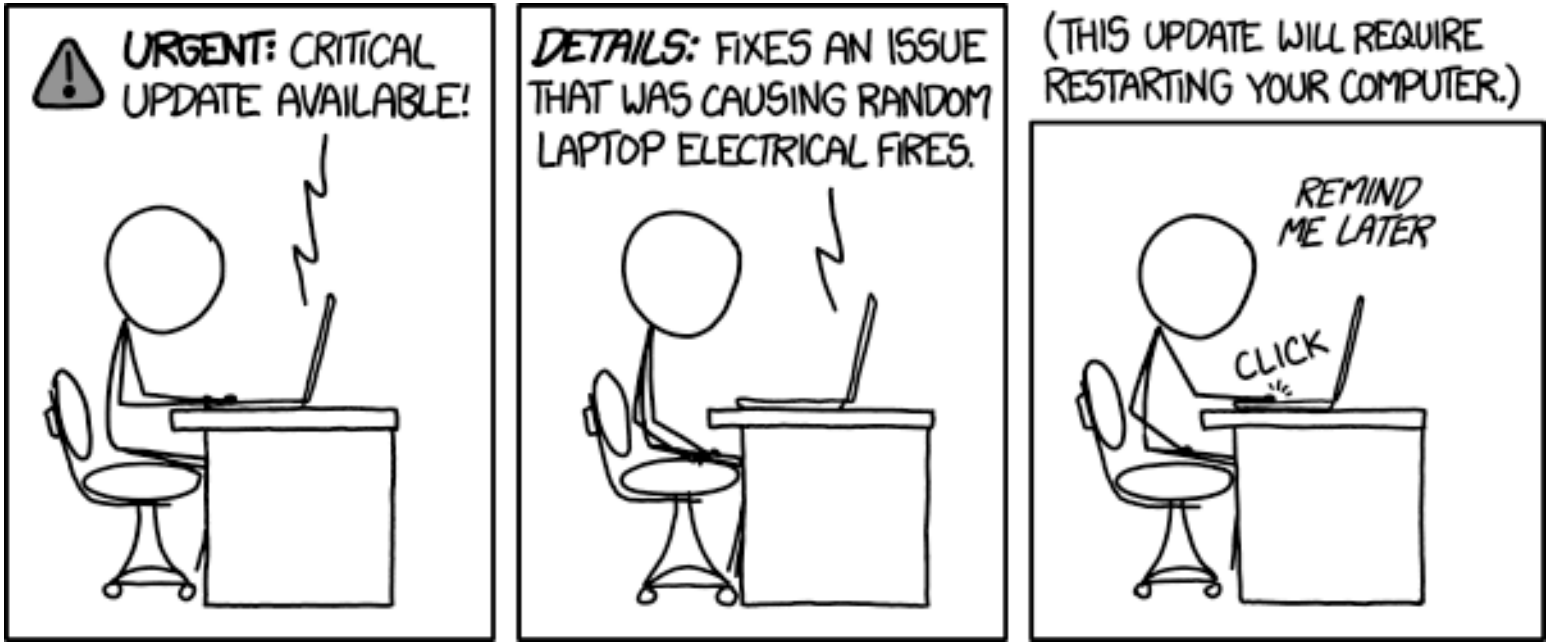
Data Security

Measures that an organization is taking in order to prevent any third party from unauthorized access.

https://dataprivacymanager.net/5-things-you-need-to-know-about-data-privacy/

Goal of teaching

Avoid «Penetrate & Patch»



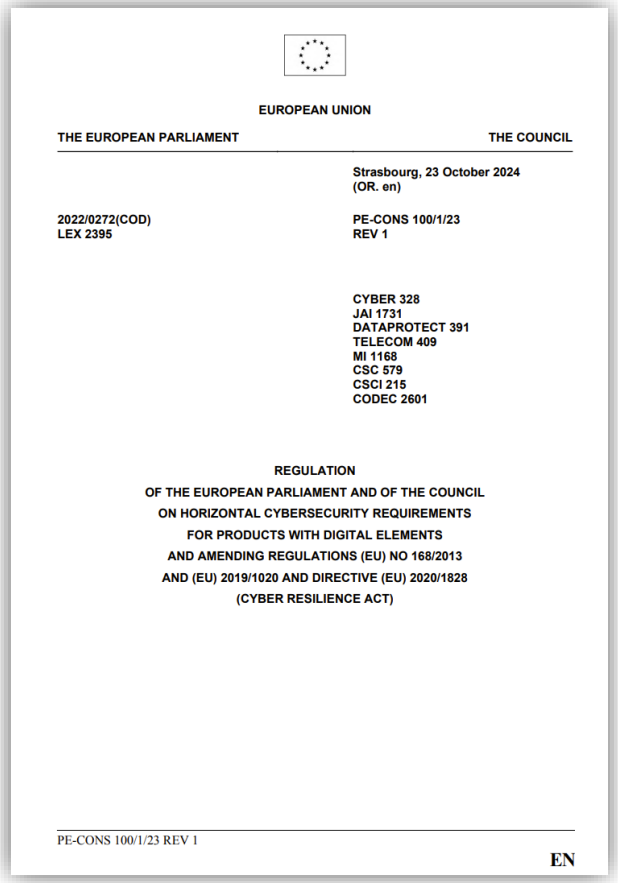
https://xkcd.com/1328

NTNU

- 54% of organizations push vulnerable code in order to meet a critical deadline, with plans to remediate in a later release.
- 29% of developers lack the knowledge to mitigate issues identified

The European Cyber Resilience Act (CRA)

- Started January 2025
- Key obligations
  - Risk assessment
  - Documentation (SDLC, SBOM, …)
  - Conformity
  - Vulnerability reporting
- Exceptions: Web-pages, OSS, …



EUROPEAN UNION

THE EUROPEAN PARLIAMENT — THE COUNCIL

Strasbourg, 23 October 2024
(OR. en)

2022/0272(COD)
LEX 2395

PE-CONS 100/1/23
REV 1

CYBER 328
JAI 1731
DATAPROTECT 391
TELECOM 409
MI 1168
CSC 579
CSCI 215
CODEC 2601

REGULATION
OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL
ON HORIZONTAL CYBERSECURITY REQUIREMENTS
FOR PRODUCTS WITH DIGITAL ELEMENTS
AND AMENDING REGULATIONS (EU) NO 168/2013
AND (EU) 2019/1020 AND DIRECTIVE (EU) 2020/1828
(CYBER RESILIENCE ACT)

PE-CONS 100/1/23 REV 1

EN

https://data.consilium.europa.eu/doc/document/PE-100-2023-REV-1/en/pdf

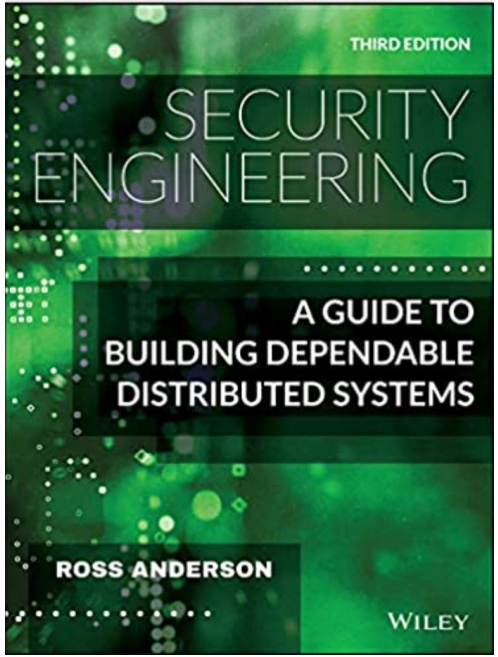
Learning outcomes

- Identify typical security vulnerabilities of web applications listed in OWASP top 10, such as SQL injection, XSS, and XSRF, by reviewing the source code and black box testing. Students should also be able to fix the identified vulnerabilities;
- Explain typical cryptography concepts and algorithms related to web application, including, e.g., block cipher, stream cipher, digital signature, and SSL/TLS handshaking procedure;
- Apply threat modeling methods to analyze web applications, learn to think like an attacker and build barriers;
- Describe and compare software engineering practices related to software security;

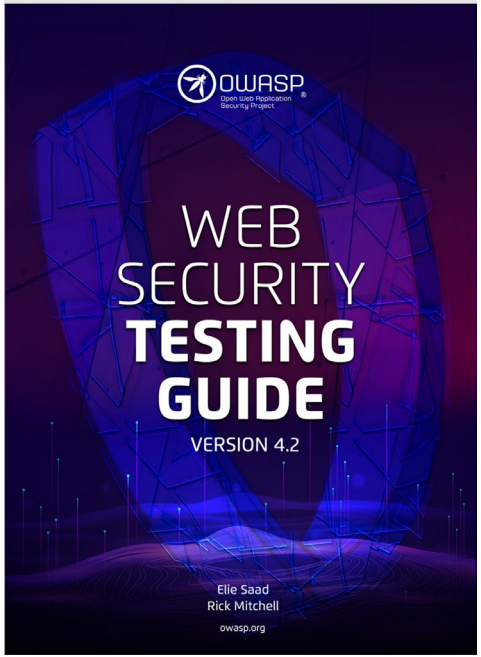
Learning outcomes (cont')

- Apply risk-based testing for development, figuring out why test? what to test? how to do it?;
- Explain key authentication and authorization concepts and methods, such as different authentication methods, multilevel security control, and role-based access control;
- Explain and apply principles of GDPR and data privacy, protecting personal spaces and avoiding hefty fines for your future tech company.
- Critical evaluation and application of AI-assisted software security tools.

Curriculum



3rd Edition
http://www.cl.cam.ac.uk/~rja14/book.html
(Buy or download free!)



https://owasp.org/www-project-web-security-testing-guide/
(Version 4.2, free!)

+ exercises and slides (free!), with referred to papers and web pages.

Lecture plan (tentative)

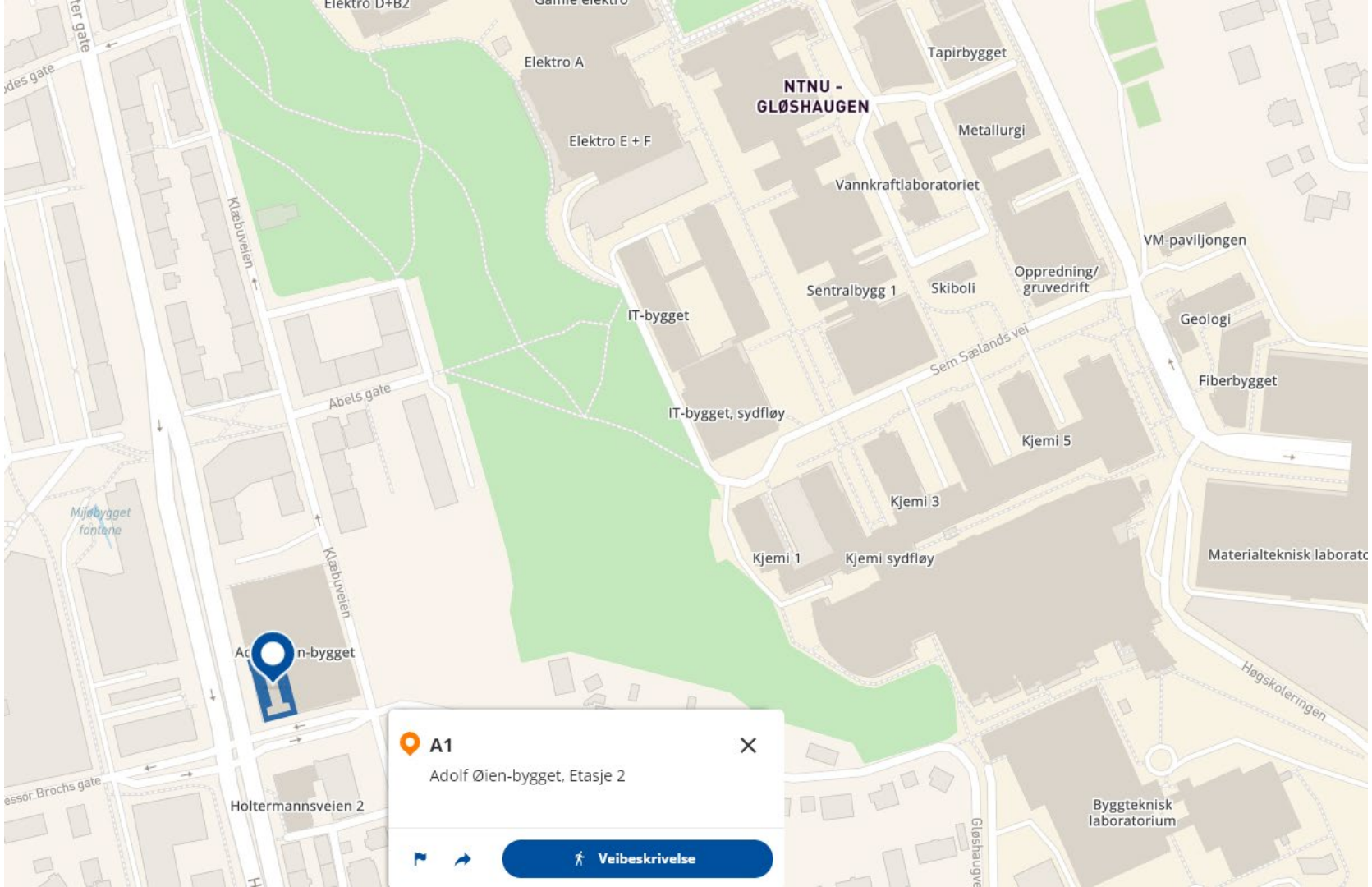
The lectures will be on Fridays from 12.15 to 14.00 at GL-AO A1

Week	Date	Theme	Lecture
3	16.01	Course Introduction Security concepts and principles	Per Håkon Meland Jingyue Li
4	23.01	Web App. OWASP part 1	Per Håkon Meland
5	30.01	Web App. OWASP part 2	Per Håkon Meland
6	06.02	Cryptography introduction	Per Håkon Meland
7	13.02	Authorization and Multi-Level Security Authentication and Single sign-on Control hijacking attacks	Per Håkon Meland
8	20.02	Winter vacation	
9	27.02	Threat modeling and STRIDE	Per Håkon Meland
10	06.03	Risk Management during development	Per Håkon Meland

Lecture plan (tentative) (cont’)

Week	Date	Theme	Lecture
11	13.03	Secure coding with LLMs Secure Development Activities and lifecycles	Jingyue Li
12	20.03	Microservice security Software supply chain security	Jingyue Li
13	27.03	Privacy by Design	Guest Lecture (Knut Soelberg from Aboveit)
14		Easter	
15		Easter	
16	17.04	Static Analysis and Tools for Security AI for Security	Guest Lecture (Tosin Daniel Oyetoyan from HVL) (Probably digital, Teams link will be provided later) Guest Lecture (Nektaria Kaloudi from SINTEF)
17	24.04	Course summary, Final Evaluation of the Course and Feedback to Professors, and more information on Exam.	Jingyue Li & Per Håkon Meland

NTNU


Elektro D+B2
Elektro A
NTNU - GLØSHAUGEN
Tapirbygget
Elektro E + F
Metallurgi
Vannkraftlaboratoriet
VM-paviljongen
Oppredning/ gruvedrift
Sentralbygg 1
Skiboli
IT-bygget
Geologi
Sem Sælands vei
Fiberbygget
Abels gate
IT-bygget, sydfløy
Kjemi 5
Kjemi 3
Kjemi 1
Kjemi sydfløy
Materialteknisk laborato
Klæbuveien
Høgskoleringen
A1
Adolf Øien-bygget, Etasje 2
Veibeskrivelse
Holtermannsveien 2
Byggteknisk laboratorium

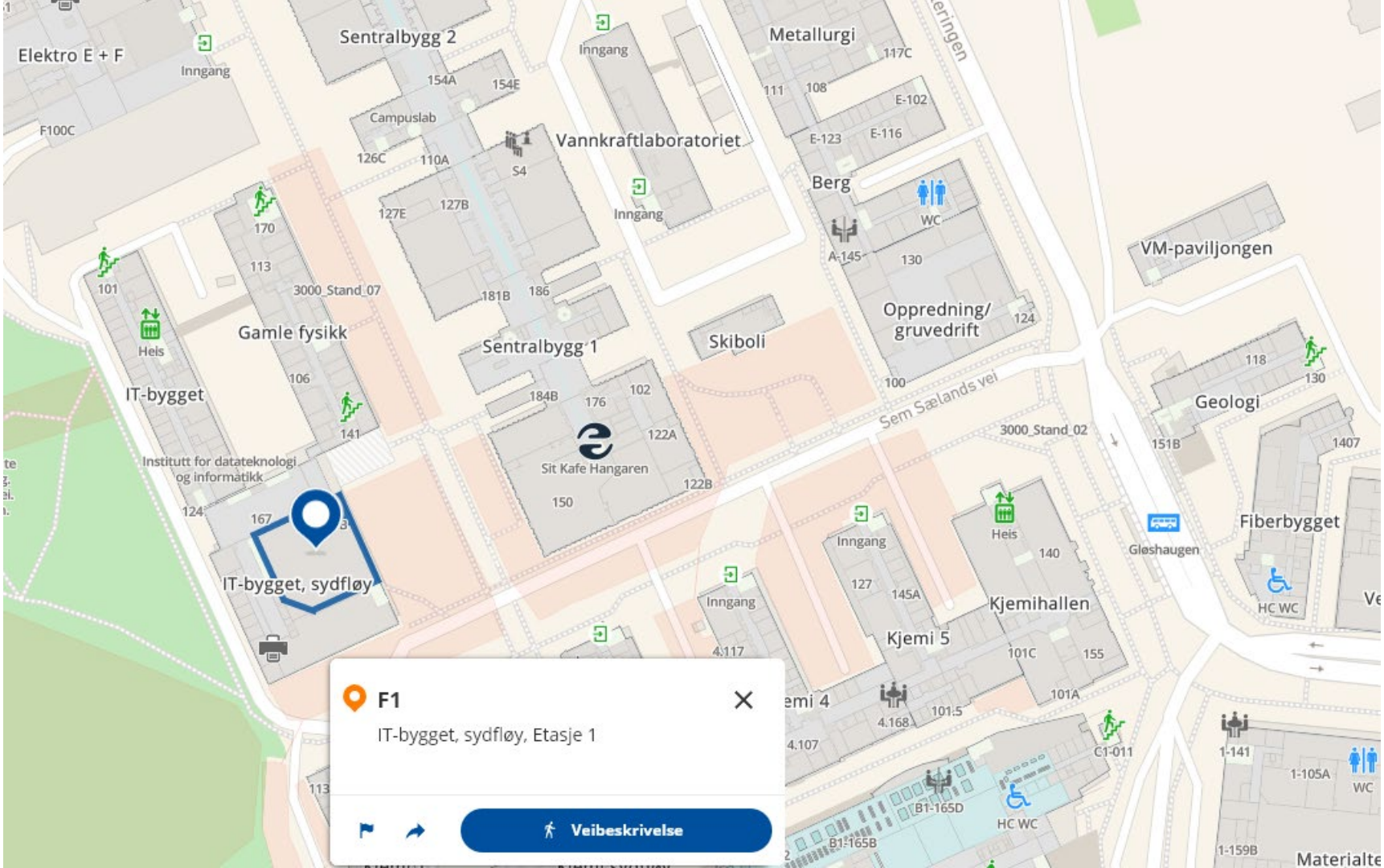
Evaluation and grading

- Exercises and written exam (16th of May, 09:00-13:00)
- Three exercises count for 100 points, in which you **must have at least 80 points in total, more than 80% each exercises 1 to 3,** to be eligible to take the exam.
- The distribution of the exercise grade is:
  - Exercise 1: 40 points (group exercise)
  - Exercise 2: 30 points (group exercise)
  - Exercise 3: 30 points (group exercise)

Exercises

- The exercise introduction lectures are on Thursdays, 08:15 - 10:00, GL-ITS F1. First one 22.01.
- Weeks without exercise introduction lectures will have teaching assistants using the same room to answer questions
- We have a discussion forum so that TAs can help answer your questions there
- TA support email: tdt4237@idi.ntnu.no

NTNU



F1

IT-bygget, sydfløy, Etasje 1

Veibeskrivelse

Deadline for exercises

- All exercises have a deadline for delivery.
- This deadline may only be exceeded after agreement with the
  - Course responsible (Jingyue.li@ntnu.no)
  - TAs (email: tdt4237@idi.ntnu.no)
- If no such agreement exists, we will deduct points on the grade for any obligatory exercise for each week it is delayed.

Exercise schedule (Tentative)

#	Weeks	Exercises schedule		
		Introduction lecture	Start	Deliverable and deadline
Exercise 1	4-10	22.01 08:15 - 10:00	22.01	**The "vulnerability" report** 04.03 at 23:59 (Wednesday), Week 10
Exercise 2	10-13	05.03 08:15 - 10:00	05.03	**Vulnerability fixes** 25.03 at 23:59 (Wednesday), Week 13
Exercise 3	13-17	26.03 08:15 - 10:00	26.03	**Threat modeling and risk management framework** 22.04 at 23:59 (Wednesday), Week 17

Exercise groups

- 1-3 students in each group (recommended 2-3 students per group)
- Use the online forum in the Blackboard to form a group
- If you cannot find a group or encounter problems signing up for a group, please send an email to the mohd.s.chishti@ntnu.no.

NTNU

TDT4237 Programvaresikkerhet og personvern (2026 VÅR)

- Course front page
- **Course content**
- Course information
- Course work
- Sources and syllabus
- Learning materials
- Previous exams
- Panopto
- Discussion Forum
- Groups

Course Management

- **Control Panel**
- Content Collection
- Course Tools
- Evaluation
- Grade Center
- Users and Groups
- Customization
- Packages and Utilities

All Groups | Group Sets | All Users

Groups

You can use the Course Groups tool to create an interactive online environment. More Help

Create | Import | Group Settings | Export

Bulk Actions | View Options

Page 1 of 6

NAME	GROUP SET	ENROLLED MEMBERS	SELF-ENROLL	AVAILABLE
TDT4237 Group 1	TDT4237 Group	0	Yes	Yes
TDT4237 Group 10	TDT4237 Group	1	Yes	Yes
TDT4237 Group 100	TDT4237 Group	1	Yes	Yes
TDT4237 Group 101	TDT4237 Group	0	Yes	Yes
TDT4237 Group 102	TDT4237 Group	0	Yes	Yes
TDT4237 Group 103	TDT4237 Group	0	Yes	Yes
TDT4237 Group 104	TDT4237 Group	0	Yes	Yes
TDT4237 Group 105	TDT4237 Group	0	Yes	Yes
TDT4237 Group 106	TDT4237 Group	0	Yes	Yes
TDT4237 Group 107	TDT4237 Group	0	Yes	Yes
TDT4237 Group 108	TDT4237 Group	0	Yes	Yes
TDT4237 Group 109	TDT4237 Group	0	Yes	Yes
TDT4237 Group 11	TDT4237 Group	0	Yes	Yes

Evaluate and develop the course

Every time the course is held, we evaluate and make a plan for improvements

Evaluation and development ensure

- that the course is relevant
- that the learning activities are useful for reaching the learning goals
- that learning goals, learning activities and assessment activities

Feedback from the students is essential (and compulsory)

More information: i.ntnu.no/emne-evaluere

Reference group and survey

- A group of 2-3 students that have a special duty to provide feedback about the course during the semester
- We'll have 2-3 short lunch meetings where we can discuss content and form of lectures and assignments
- The group should be formed during the first 3 weeks, so please nominate yourself (or others)!
- Send an email to Jingyue.li@ntnu.no

  if you are interested by 6th of Feb.

Warning

- Do not try any of the attacks discussed in this course on real production web sites!!!

- You can try security testing with:
  - Your own application
  - Applications for teaching purpose, e.g.:
    - OWASP Juice shop https://owasp.org/www-project-juice-shop/
    - OWASP WebGoat https://github.com/WebGoat/WebGoat/
    - Damn Vulnerable Web Application (DVWA) https://github.com/digininja/DVWA
  - SW call for help. Hackathons. Bug Bounties.
  - The exercise application of this course (please don't DDOS NTNU)

About you

- We need to know a little more about you to adapt our teaching focus and exercises!